# ACCESS CONTROL POLICY

*POL-008 | Issued under the Information Management Framework*

**Document ID:** POL-008
**Version:** 1.0 — DRAFT
**Parent Framework:** IMF-001 — Information Management Framework
**Classification:** Internal Use
**Owner:** Chief Information Security Officer
**Effective Date:** [DATE]
**Review Date:** [DATE + 1 Year]

**CONFIDENTIAL — FOR INTERNAL USE ONLY**

# Document Control

| Field | Detail |
|---|---|
| Document Title | Access Control Policy |
| Document ID | POL-008 |
| Version | 1.0 — DRAFT |
| Status | Draft for Review |
| Parent Framework | IMF-001 — Information Management Framework |
| Document Owner | Chief Information Security Officer (CISO) |
| Custodian | Information Security |
| Effective Date | [DATE] |
| Next Review Date | [DATE + 1 Year] |
| Regulatory Alignment | 21 CFR Part 11, EU Annex 11, GDPR Art. 5/32, HIPAA Security Rule, SOX (ITGC), ISO/IEC 27001:2022 (A.5.15–A.5.18, A.8.2–A.8.5), NIST SP 800-53 (AC family) |

## Revision History

| Version | Date | Author | Description |
|---|---|---|---|
| 0.1 | [DATE] | [Author] | Initial draft |
| 1.0 | [DATE] | [Author] | Issued for review |

# 1. Purpose

This Policy establishes the requirements for controlling access to [Company Name]'s information systems, data, and technology resources. Access control is the primary mechanism for ensuring that individuals can access only the systems and data they need to perform their role — no more, and no less.

This Policy operationalises the principle of least privilege across the full identity lifecycle: from the moment an individual is granted their first account through to the revocation of all access when they leave. The rigour of access controls scales with the criticality and regulatory status of the system — access review frequency, multi-factor authentication requirements, and approval thresholds are all determined by the system's classification under POL-005.

> **IMPORTANT:** For GxP systems: individual user accounts are not merely a security control — they are a regulatory requirement. 21 CFR Part 11 and EU Annex 11 require that every electronic record and signature be attributable to a specific individual. Shared, generic, or group accounts in GxP systems are prohibited without exception and constitute an ALCOA+ violation (Attributable principle) as defined in POL-003.

# 2. Scope

This Policy applies to all access to [Company Name] systems, applications, data, and infrastructure — including physical access to server rooms and data centres where these intersect with logical access control. It applies to:

- All employees, contractors, consultants, temporary staff, and third-party vendors who access any [Company Name] system
- All systems classified under POL-005, from Tier 1 (Extremely Critical) to Tier 4 (Low Criticality)
- All access methods: direct login, remote access (VPN, remote desktop, cloud console), API access, service account access, and privileged/administrative access
- Third-party SaaS and cloud platforms where [Company Name] data is held or processed

Privileged and administrative access is governed additionally by POL-009 (Privileged Access Management Policy). Where POL-009 imposes more stringent requirements than this Policy, POL-009 takes precedence.

# 3. Governing Principles

| Principle | Definition and Application |
|---|---|
| Least Privilege | Every user, process, and system account is granted the minimum access required to perform its function — nothing more. Access is never granted as a convenience or 'just in case'. Additional access requires a documented business justification and is subject to the approval thresholds in Section 5. |
| Need to Know | Access to data is granted based on a specific operational need. Membership of a team or seniority of role does not automatically confer access to all data the team or department handles. |
| Individual Accountability | Every action on every system must be attributable to a specific, identified individual. Shared accounts, group accounts, and generic accounts are prohibited on all Tier 1, Tier 2, and all GxP-flagged systems regardless of tier. For Tier 3/4 non-GxP systems: shared accounts require CISO approval and compensating controls. |
| Separation of Duties | Duties that, if combined, would allow an individual to commit and conceal fraud, error, or a data integrity failure are separated between different individuals. No single person should be able to initiate, approve, and record the same financial or regulated transaction. |
| Default Deny | Access is denied by default. A user or process has no access to a system unless access has been explicitly granted through the provisioning process defined in Section 5. There is no implied access from role, seniority, or departmental membership. |
| Access Proportionality | Access review frequency, MFA requirements, and approval thresholds scale with the criticality tier and regulatory flags of the system. Higher tiers and regulated systems receive more stringent controls. This is the access control expression of the same proportionality principle applied in POL-006 (assurance tracks) and POL-007 (change approval tiers). |

# 4. Identity Lifecycle

Every identity — employee, contractor, service account, or system identity — passes through the same lifecycle: creation, modification over time, and eventual revocation. This Policy governs all three stages for all identity types.

## 4.1 Identity Provisioning

Access provisioning is initiated by an approved access request. No access may be provisioned without a completed and approved access request, regardless of urgency. The access request must document: the system(s) requested, the specific roles or permissions requested, and the business justification.

| System Type | Requester | Approver(s) | Provisioning Timeframe |
|---|---|---|---|
| Tier 1 / GxP-flagged | Line Manager | System Owner + Information Security. For GxP: Compliance / QA must confirm the individual has completed mandatory data integrity training (SOP-003) before access to GxP systems is granted. | Within 5 business days of approval |
| Tier 2 (SOX-scoped) | Line Manager | System Owner + Information Security | Within 5 business days of approval |
| Tier 2 (non-SOX) | Line Manager | System Owner | Within 3 business days of approval |
| Tier 3 | Line Manager | System Owner | Within 3 business days of approval |
| Tier 4 | Requestor | Line Manager confirmation | Within 2 business days |

**GxP:** For GxP systems: the provisioning step must include confirmation that the individual's training record in the training management system shows completion of mandatory data integrity training per SOP-003. Information Security must not provision GxP system access without this confirmation from Compliance / QA.

## 4.2 Role-Based Access Control (RBAC)

Access to all Tier 1 and Tier 2 systems, and all GxP-flagged systems, must be structured using Role-Based Access Control. Access is granted by assigning an individual to a pre-defined role — the role carries the permissions, not the individual account. Ad-hoc permission grants that bypass RBAC roles are prohibited on these systems.

Role definitions must be documented and maintained by the System Owner. Roles must be designed to enforce the least privilege and separation of duties principles. Role definitions are reviewed at each access review cycle and whenever a significant organisational change affects the function the role supports.

For Tier 3 and Tier 4 systems without a regulatory flag, RBAC is strongly recommended but not mandatory. Where individual permission grants are used, they must be documented and included in access reviews.

## 4.3 Joiners, Movers, and Leavers

| Event | Required Action | Timeline | Responsible |
|---|---|---|---|
| New joiner | HR notifies Information Security and relevant System Owners. Access provisioned per approved access request (Section 4.1). For GxP systems: no access until training confirmation received. | Access provisioned on or after first day. No pre-provisioning of GxP system access. | HR / Line Manager / Information Security |
| Internal transfer (Mover) | Line Manager submits access modification request. Previous role access is revoked within the timeframe below. New role access provisioned per normal process. For movements out of GxP roles: GxP system access revoked on the transfer date. | Old access revoked within 1 business day of transfer effective date. New access provisioned within 3 business days. | Line Manager / Information Security / System Owner |
| Role change (same position) | Line Manager submits access modification request. Excess permissions from previous role are removed. New permissions provisioned. Both actions must occur simultaneously — no period where the individual holds both old and new permissions. | Within 3 business days of role change effective date. | Line Manager / Information Security |
| Leaver (voluntary or involuntary) | HR notifies Information Security on the last working day. All system access revoked by end of the last working day. For involuntary departures: CISO may direct immediate revocation on notification — before the end of the working day. Remote access (VPN, email, cloud) revoked first. | All access revoked by end of last working day. Remote access: immediately on notification for involuntary departures. | HR / Information Security / Data Custodian (IT) |
| Extended leave (>30 days) | Access to Tier 1 and Tier 2 systems and all GxP-flagged systems is suspended for the duration of leave. Not revoked — | Suspension applied on first day of leave for Tier 1/2 and GxP | HR / Information Security |

| Event | Required Action | Timeline | Responsible |
|---|---|---|---|
| | suspended, so it can be reinstated without a new access request on return. Access to Tier 3/4 systems: System Owner discretion. | systems. | |
| Contractor / consultant departure | Sponsor (the internal employee who requested the contractor's access) notifies Information Security. All access revoked by end of the final day of engagement. | Access revoked by end of final engagement day. | Sponsor / Information Security |

# 5. Multi-Factor Authentication

Multi-factor authentication (MFA) requires a user to verify their identity using at least two independent factors: something they know (password), something they have (token, authenticator app, hardware key), or something they are (biometric). MFA requirements scale with system criticality tier and access method.

| Access Scenario | MFA Requirement | Approved MFA Methods |
|---|---|---|
| Any remote access (VPN, RDP, cloud console, SSH from outside the corporate network) | Mandatory — no exceptions | TOTP authenticator app, hardware security key (FIDO2), push notification to approved authenticator app |
| Tier 1 systems — all access (including on-premises) | Mandatory — no exceptions | Hardware security key (FIDO2) strongly recommended. TOTP authenticator app acceptable. SMS OTP is NOT an approved method for Tier 1. |
| Tier 2 systems — all access (including on-premises) | Mandatory | TOTP authenticator app, hardware security key, push notification |
| Tier 3 systems — remote access or access from unmanaged devices | Mandatory | TOTP authenticator app, push notification. SMS OTP acceptable for Tier 3 only with CISO approval. |
| Tier 4 systems | Recommended, not mandatory. Required for remote access. | Any approved MFA method |
| Privileged / administrative access — all tiers and systems | Mandatory — governed by POL-009 | Hardware security key (FIDO2) required for Tier 1 privileged access. See POL-009. |
| Service accounts and API access | MFA not applicable — governed by POL-009 service account controls | N/A |

**IMPORTANT:** SMS OTP (one-time password delivered by text message) is not approved for Tier 1 or Tier 2 systems due to SIM-swapping and interception risks. Any existing SMS OTP implementations for Tier 1/2 access must be migrated to an approved method within 90 days of this Policy's effective date.

# 6. Password Standards

Password standards apply to all accounts where password authentication is used. These standards represent the minimum — individual systems may apply more stringent requirements where technically feasible.

| Standard | Tier 1 / GxP | Tier 2 | Tier 3 | Tier 4 |
|---|---|---|---|---|
| Minimum length | 16 characters | 14 characters | 12 characters | 10 characters |
| Complexity requirement | Upper + lower + digit + symbol | Upper + lower + digit | Upper + lower + digit | Upper + lower |
| Maximum age | 90 days | 180 days | 1 year | No mandatory rotation |
| Account lockout (failed attempts) | 5 attempts → 30 min lockout | 5 attempts → 15 min lockout | 10 attempts → 15 min lockout | 10 attempts |
| Password history | Last 12 passwords | Last 8 passwords | Last 6 passwords | Last 4 passwords |
| Password manager use | Mandatory for complex passwords | Strongly recommended | Recommended | Optional |

Passwords must never be shared, written down in an accessible location, transmitted in plaintext, or reused across systems. Where a system does not technically support the minimum password standard for its tier, the System Owner must document the limitation as a known risk and implement compensating controls (e.g., more frequent access reviews, enhanced monitoring).

# 7. Periodic Access Reviews

Periodic access reviews are mandatory for all Tier 1, Tier 2, and all GxP-flagged or SOX-scoped systems. Their purpose is to confirm that current access grants remain appropriate — that the right people have access and no one who should not have access does.

| System Type | Review Frequency | Reviewer | Scope |
|---|---|---|---|
| Tier 1 / GxP-flagged | Quarterly | System Owner, verified by Information Security | All active user accounts and their assigned roles. Administrator and privileged accounts reviewed per POL-009. |
| Tier 2 (SOX-scoped) | Quarterly (aligned with SOX ITGC testing cadence) | System Owner, documented for SOX evidence | All active user accounts. Access rights compared against current job function. |
| Tier 2 (non-SOX) | Semi-annual | System Owner | All active user accounts and roles. |
| Tier 3 | Annual | System Owner | All active user accounts. |
| Tier 4 | Annual (or on material organisational change) | System Owner | Active user accounts. |

## 7.1 Access Review Process

For each review, the System Owner must:

- Obtain the current user access list from the system (not a cached or manually maintained list — the authoritative system export)
- Confirm that each account belongs to an active employee or contractor with a current business need for the access
- Confirm that the access level (role or permissions) remains appropriate for the individual's current function
- Identify and revoke any accounts for former employees, movers whose old access was not removed, or individuals whose role no longer requires the access
- For GxP systems: confirm no generic, shared, or test accounts remain active in the production environment
- Document the review: date, reviewer, accounts confirmed, accounts removed, and rationale for any accounts that were scrutinised but retained

Access review records must be retained for 3 years for non-GxP systems and for the applicable GxP retention period for GxP systems. For SOX-scoped systems, access review records are SOX ITGC evidence and must be retained for 7 years per POL-002.

**GxP:** A common inspection finding is access review documentation that shows 'confirmed' for every account without evidence of actual scrutiny. Regulators expect to see accounts removed during reviews. If a review never results in any access changes, it will be challenged. Document your scrutiny, not just your conclusion.

# 8. Remote Access

Remote access to [Company Name] systems from outside the corporate network is controlled and monitored. The following requirements apply to all remote access regardless of the system accessed.

- All remote access must route through the approved corporate VPN or equivalent zero-trust network access (ZTNA) solution — direct internet access to internal systems is prohibited
- MFA is mandatory for all remote access per Section 5
- Access from personal (unmanaged) devices is prohibited for Tier 1 and Tier 2 systems and all GxP-flagged systems. Tier 3/4 access from personal devices requires CISO approval and use of a virtual desktop or equivalent isolation mechanism
- Remote access sessions to Tier 1 systems must have an automatic inactivity timeout of 15 minutes. Tier 2: 30 minutes. Tier 3/4: 60 minutes
- Third-party and vendor remote access requires a specific, time-limited access grant for each maintenance session — persistent vendor remote access to production systems is prohibited. Sessions must be monitored or recorded per POL-009

Remote access capability is provisioned and revoked as part of the identity lifecycle process. An individual whose employment or engagement ends loses remote access as their first access revocation, not their last.

# 9. Third-Party and Vendor Access

Third parties (suppliers, vendors, auditors, regulators, consultants) who require access to [Company Name] systems must be sponsored by an internal employee (the Sponsor) who takes accountability for the appropriateness and scope of that access.

| Requirement | Detail |
|---|---|
| Sponsorship | Every third-party user must have a named internal Sponsor. The Sponsor is responsible for requesting access, confirming the business need at each renewal, and notifying Information Security immediately when the engagement ends. |
| Named individual accounts | Third-party vendors must use named individual accounts — not shared vendor accounts. This applies to all Tier 1, Tier 2, and GxP-flagged systems without exception. Shared vendor accounts on these systems are prohibited. |
| Time-limited access | Third-party access is granted for a defined period only (maximum 12 months without renewal). Access automatically expires at the end of the defined period. Renewal requires a new access request approved by the Sponsor and System Owner. |
| Minimum scope | Third-party access is scoped to the minimum required for the specific engagement. A vendor supporting one application does not receive access to others. |
| DPA and confidentiality | Before any third party accesses a system containing personal data, a Data Processing Agreement (DPA) must be in place per POL-004 and POL-013. Confidentiality agreements must be in place before any access to Sensitive (Tier 3) or higher classified information. |
| GxP vendor access | Third-party access to GxP-validated systems requires Compliance / QA notification and assessment of the impact on validation status. Vendor changes to GxP system configuration must go through POL-007 change management. |
| Monitoring | Third-party sessions on Tier 1 and all GxP-flagged systems are subject to session monitoring or recording per POL-009. Vendors are informed of this monitoring at the time of access provisioning. |

# 10. Access Control Requirements for GxP Systems (21 CFR Part 11 / EU Annex 11)

Systems carrying a GxP regulatory flag are subject to additional access control requirements derived from 21 CFR Part 11 (US) and EU Annex 11 (Europe). These requirements are non-negotiable and must be demonstrated during regulatory inspections.

| Requirement | Obligation | Verification |
|---|---|---|
| Individual user accounts (Part 11 §11.10(d); Annex 11 §12.1) | Every user of a GxP system must have a unique individual login. The system must technically prevent credential sharing. Generic, group, training, and test accounts must not exist in the production GxP environment. | Access review confirms no generic/shared accounts exist. Access review records retained as validation evidence. |
| Operational authority checks (Part 11 §11.10(d); Annex 11 §12.1) | The system must technically limit system access and data entry or modification to authorised individuals only. RBAC roles must enforce this — access to create, modify, or delete a record must be restricted to authorised roles. | RBAC role definitions documented in URS. OQ testing confirms access restrictions are enforced by the system. |
| Account inactivity controls (Part 11 §11.10(d)) | Accounts that have not been used for 90 days on a GxP system must be suspended. Suspended accounts are not deleted — they must be available for audit trail review. Accounts can be reinstated following a new access request. | Automated inactivity monitoring or manual quarterly review of last-login dates. |
| Secure password / credential management (Part 11 §11.300) | Combinations of identification code / password used for electronic signatures must be periodically checked, recalled, or revised. The system must enforce password standards at minimum equal to the Tier 1 requirements in Section 6. | Password policy configuration confirmed in OQ. |
| Audit trail — access changes (Part 11 §11.10(e); Annex 11 §9) | All access grant, modification, and revocation events must be captured in the system audit trail with timestamp, user identity of the administrator performing the action, and the access changed. Audit trail of access changes must be reviewed as part of the periodic audit trail review per SOP-003. | Audit trail configuration validated in OQ. Access change events confirmed in audit trail review. |
| System access log monitoring | Login events, failed login attempts, and account lockouts must be logged and included in the periodic audit trail review per SOP-003. Anomalous access patterns (logins at unusual hours, failed login spikes) must be investigated. | Confirmed in SOP-003 audit trail review schedule. |

# 11. Access Control for SOX In-Scope Systems (ITGC)

Systems carrying a SOX regulatory flag are subject to ITGC logical access controls that will be tested annually by Internal Audit and the external auditor. The following access control evidence must be produced and retained for SOX-scoped systems:

- Quarterly access reviews: the user access list, review sign-off, and documentation of any changes made — retained as SOX evidence for 7 years
- Provisioning and deprovisioning records: evidence that access was appropriately approved on joining and revoked on departure — sampled by auditors
- Segregation of duties matrix: documentation that conflicting access rights (e.g., the ability to both create and approve financial transactions) are not granted to the same individual
- Privileged access controls: evidence per POL-009 that administrator access to SOX systems is controlled and reviewed

Failures in SOX ITGC logical access controls — particularly failure to revoke access on departure or failure to perform access reviews — are among the most common SOX material weaknesses identified by external auditors.

# 12. Roles and Responsibilities

| Role | Responsibility |
|---|---|
| CISO | Policy owner. Approves exceptions. Owns MFA and remote access standards. Reviews quarterly access compliance metrics. |
| Information Security | Implements and monitors access controls across all tiers. Manages identity platform. Executes provisioning and deprovisioning for enterprise systems. Reviews access review documentation for completeness. |
| System Owner | Conducts periodic access reviews for their systems. Maintains RBAC role definitions. Approves access requests for their systems. Notifies Information Security of access anomalies. |
| Line Manager | Initiates access requests for their team members. Notifies HR and Information Security immediately on any staffing change. Reviews access appropriateness for direct reports at least annually. |
| HR | Notifies Information Security of all joiners, movers, and leavers on or before the effective date. Maintains the authoritative list of active employees and contractors for identity reconciliation. |
| Compliance / QA | Confirms mandatory data integrity training completion before GxP system access is provisioned. Reviews GxP system access reviews for Part 11 compliance. Provides access control evidence for regulatory inspections. |
| Data Custodian (IT) | Implements technical access controls per System Owner requirements. |

| Role | Responsibility |
|---|---|
| | Executes access revocation on departure. Provides access reports for access reviews. |
| All Users | Protect credentials. Never share accounts or passwords. Report suspected unauthorised access immediately to Information Security. Complete mandatory access control training. |

# 13. Related Documents

| Document ID | Title | Relationship |
|---|---|---|
| IMF-001 | Information Management Framework | Parent framework |
| POL-003 | Data Integrity Policy | ALCOA+ Attributable principle requires individual user accounts in GxP systems — this Policy delivers that requirement technically |
| POL-005 | System Classification Policy | System criticality tier and regulatory flags determine access control requirements, review frequency, and MFA obligations under this Policy |
| POL-006 | Computer System Validation and Qualification Policy | Access control requirements (Part 11/Annex 11) must be captured in the URS and tested in OQ for Track A (GxP) systems |
| POL-007 | Change Management Policy | Changes to access control configurations and RBAC roles are changes governed by POL-007; access role changes for GxP systems require validation impact assessment |
| POL-009 | Privileged Access Management Policy | Elevated controls for administrative, root, and service accounts — supplements this Policy for privileged identities |
| POL-010 | Information Security Risk Policy | Access control failures — stale accounts, excessive privilege, SoD violations — are IS Operational risks assessed and tracked under POL-010; access review frequency is a risk-proportionate control calibrated to the risk scoring framework |
| POL-014 | Audit Trail and Monitoring Policy | Access control events — account creation, modification, deletion, permission grants — are a mandatory audit trail category under POL-014; access review evidence is drawn from audit trail records; access review records are retained as audit evidence |
| POL-012 | Incident Response Policy | Unauthorised access events, compromised |

| Document ID | Title | Relationship |
|---|---|---|
| | | accounts, and access control violations are security incidents under POL-012; access review findings that reveal historical unauthorised access may be incident triggers; deprovisioning failures exploited by attackers are a common incident root cause |
| POL-004 | Privacy Policy | Access controls for systems holding personal data (Tier 4 / GDPR Special Category) — Article 32 technical measure |
| POL-013 | Third Party and Vendor Risk Policy | DPA and vendor access governance; third-party access requirements in Section 9 |
| SOP-003 | Data Integrity Process | Audit trail review includes access change events; access anomaly patterns are data integrity incident triggers |
| SOP-004 | Privacy Process | DSR handling requires data custodian access to execute technical actions; access must be controlled and auditable |
| EXC-001 | Exception Management Policy and Register | Access control exceptions — including MFA exceptions and over-provisioning — are subject to EXC-001 with a 3-month maximum duration; shared accounts on GxP systems are non-approvable per EXC-001 Section 5; compensating controls typically include enhanced monitoring and reduced access scope |
| RACI-001 | Roles, Responsibilities and Authorities | Access and identity management accountability |

# 14. Definitions

| Term | Definition |
|---|---|
| Access Control | The practice of restricting access to systems, data, and resources to authorised individuals and processes only. |
| Identity Lifecycle | The complete journey of an identity from creation (joiner) through changes (mover) to deactivation (leaver). |
| Least Privilege | The principle that every identity is granted only the minimum permissions required to perform its function. |
| MFA (Multi-Factor Authentication) | Authentication using two or more independent factors to verify identity before granting access. |
| RBAC (Role-Based | An access control model where permissions are assigned to roles, and |

| Term | Definition |
|---|---|
| Access Control) | users are assigned to roles, rather than permissions being assigned directly to individual users. |
| Separation of Duties | The practice of dividing critical tasks between multiple individuals to prevent any single person from being able to commit and conceal an error or fraud. |
| Shared Account | An account whose credentials are known to and used by more than one individual. Prohibited on all Tier 1, Tier 2, and GxP-flagged systems. |
| Sponsor | The internal employee who requests and takes accountability for a third party's system access. |

*— End of Document —*

POL-008 v1.0 DRAFT | [Company Name] | CONFIDENTIAL